

Modelo de Encuesta Integral AMPARO-ENS

Diagnóstico de Indicadores y Métricas de Ciberseguridad en Organizaciones que se Relacionan con el Sector Público Español

Esta encuesta está dirigida a responsables de seguridad de la información (CISO), responsables de TI, responsables de cumplimiento ENS/NIS2, gerencia de riesgos y equipos afines.

No es un examen, es un espejo. Lo que devuelva depende, en buena medida, de la honestidad con la que se mire.

0. Información general de la organización

0.1. Tipo de entidad

Seleccione la opción que mejor describa a su organización.

- ☐ Administración General del Estado (AGE)
- ☐ Administración Autonómica
- ☐ Administración Local
- ☐ Organismo público / Entidad de derecho público
- ☐ Empresa pública
- ☐ Entidad privada que presta servicios al sector público
- ☐ Proveedor tecnológico / integrador / outsourcing de TI
- ☐ Otra (especificar): ____

0.2. Tamaño aproximado de la organización (personas empleadas)

- ☐ Micro (1-9)
- ☐ Pequeña (10-49)
- ☐ Mediana (50-249)
- ☐ Grande (250-999)
- ☐ Muy grande (≥ 1.000)

0.3. Ámbito principal de actividad (puede marcar más de una)

- ☐ Administración general
- ☐ Hacienda / Finanzas públicas
- ☐ Salud
- ☐ Educación / Universidades
- ☐ Justicia / Interior / Seguridad
- ☐ Servicios sociales
- ☐ Transporte / Movilidad
- ☐ Agua / Energía / Medio ambiente
- ☐ TIC / Servicios digitales
- ☐ Otro (especificar): ____

0.4. Rol de la persona que responde

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CIO / Responsable de TI
- ☐ Responsable de Cumplimiento ENS / NIS2
- ☐ Responsable de Riesgos / Auditoría
- ☐ Dirección General / Gerencia
- ☐ Otro (especificar): ____

0.5. ¿Su organización está actualmente certificada en ENS?

- ☐ Sí, con alcance parcial (algunos sistemas)
- ☐ Sí, con alcance global (todos los sistemas relevantes)
- ☐ En proceso formal de certificación
- ☐ Alineada sin certificación formal
- ☐ No, ni alineada ni certificada
- ☐ No aplica / No sabe

1. Gobierno, madurez y cumplimiento ENS

1.1. Modelo de gobierno de seguridad

1.1.1. ¿Existe una política de seguridad de la información formalmente aprobada por el órgano de dirección competente?

- ☐ Sí, aprobada y vigente (revisión $\leq$ 2 años)
- ☐ Sí, pero desactualizada (última revisión $>$ 2 años)
- ☐ En elaboración / pendiente de aprobación
- ☐ No existe política formal
- ☐ No sabe / No responde

1.1.2. ¿Quién aprueba la política de seguridad?

- ☐ Órgano colegiado de gobierno (Consejo, Pleno, etc.)
- ☐ Comisión delegada (Comité de Dirección, Comité de Seguridad)
- ☐ Dirección de TI o equivalente
- ☐ Responsable de Seguridad de la Información (sin refrendo superior)
- ☐ Otro (especificar): ____

1.1.3. ¿Dispone su organización de un Comité de Seguridad de la Información u órgano equivalente?

- ☐ Sí, formalmente constituido y activo
- ☐ Sí, existe en papel pero se reúne de forma esporádica
- ☐ No, pero se está valorando su creación
- ☐ No existe ni se prevé su creación a corto plazo

1.1.4. Frecuencia con la que el máximo órgano de dirección recibe información sobre el estado de la ciberseguridad y el ENS:

- ☐ Mensual
- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Solo ad hoc, tras incidentes graves
- ☐ Nunca / No consta

1.2. Uso de INES y AMPARO

1.2.1. En relación con el Informe INES y la herramienta asociada:

- ☐ La organización cumplimenta el Informe INES anualmente de forma sistemática
- ☐ La organización lo cumplimenta, pero con retrasos o irregularidades
- ☐ Solo se ha rellenado una vez, de forma puntual
- ☐ Todavía no se ha cumplimentado, pero se prevé hacerlo
- ☐ No se utiliza ni se prevé utilizar (no se considera obligado)
- ☐ No sabe / No responde

1.2.2. Respecto a AMPARO como herramienta de gobernanza ENS:

- ☐ Se utiliza como repositorio central de documentación ENS (políticas, DA, evidencias)
- ☐ Se utiliza principalmente para planificar el Plan de Adecuación ENS
- ☐ Se utiliza solo para preparar auditorías o inspecciones
- ☐ Se ha evaluado, pero no se utiliza por cuestiones operativas
- ☐ No se conoce / No se utiliza en absoluto

1.2.3. ¿Se utiliza AMPARO o herramientas equivalentes para mantener actualizada la Declaración de Aplicabilidad ENS (DA)?

- ☐ Sí, la DA está al día y es coherente con la realidad de los sistemas
- ☐ Sí, pero la DA lleva más de 12 meses sin revisión
- ☐ La DA está en elaboración
- ☐ No existe Declaración de Aplicabilidad formal
- ☐ No sabe / No responde

1.3. Perfil de cumplimiento y madurez ENS

1.3.1. Nivel de implantación de las medidas ENS (promedio estimado):

- ☐ < 40 % de las medidas relevantes implantadas
- ☐ 40–60 %
- ☐ 61–80 %
- ☐ > 80 %
- ☐ No se dispone de estimación razonable

1.3.2. ¿Se ha definido un Perfil de Cumplimiento Específico (PCE) para los sistemas principales?

- ☐ Sí, documentado y aprobado
- ☐ Sí, pero aún no formalmente aprobado
- ☐ No, pero se asume el perfil genérico ENS
- ☐ No se ha trabajado con perfiles de cumplimiento
- ☐ No sabe / No responde

1.3.3. ¿Se han identificado explícitamente los sistemas sujetos a ENS y su categoría (BÁSICA, MEDIA, ALTA)?

- ☐ Sí, inventario y categorización completados
- ☐ Parcialmente (solo sistemas más críticos)
- ☐ En proceso de identificación y categorización
- ☐ No se ha realizado este ejercicio
- ☐ No sabe / No responde

1.3.4. ¿Con qué frecuencia se revisa el estado de adecuación al ENS?

- ☐ Al menos una vez al año
- ☐ Cada 2–3 años
- ☐ Solo cuando hay cambios significativos o auditorías
- ☐ No se revisa de forma sistemática

2. Análisis de riesgos, Zero Trust y protección criptográfica

2.1. Análisis y gestión de riesgos

2.1.1. ¿Qué metodología de análisis de riesgos se utiliza principalmente?

- ☐ MAGERIT, apoyada en PILAR u otra herramienta oficial
- ☐ Otra metodología formal (ISO 27005, OCTAVE, EBIOS, etc.)
- ☐ Metodologías propias documentadas
- ☐ Evaluaciones ad hoc sin metodología formal
- ☐ No se realiza análisis de riesgos de forma sistemática

2.1.2. Frecuencia del análisis de riesgos sobre sistemas sujetos a ENS:

- ☐ Anual
- ☐ Cada 2 años
- ☐ Cada 3 años o más
- ☐ Solo ante cambios relevantes de sistemas
- ☐ No se realiza de forma periódica

2.1.3. ¿Se dispone de un registro centralizado de riesgos de ciberseguridad?

- ☐ Sí, con riesgos priorizados, responsables y planes de tratamiento
- ☐ Sí, pero sin priorización clara ni responsables asignados
- ☐ Existe, pero está desactualizado
- ☐ No se dispone de un registro estructurado
- ☐ No sabe / No responde

2.1.4. ¿Se ha definido explícitamente el apetito de riesgo en ciberseguridad por parte de la alta dirección?

- ☐ Sí, documentado y comunicado
- ☐ Sí, de manera informal, pero no documentado
- ☐ No, pero se está trabajando en ello
- ☐ No, y no está previsto
- ☐ No sabe / No responde

2.2. Arquitectura Zero Trust (Confianza Cero)

2.2.1. ¿Cuál de las siguientes descripciones refleja mejor el estado de su organización respecto a Zero Trust?

- ☐ No se ha abordado el concepto; se sigue un modelo clásico “perímetro-centrado”
- ☐ Se han implantado medidas puntuales (MFA, VPN, segmentación), pero sin un marco Zero Trust definido
- ☐ Existe una estrategia formal de transición a Zero Trust (roadmap, objetivos, hitos)
- ☐ Se considera que el modelo de seguridad es predominantemente Zero Trust
- ☐ No sabe / No responde

2.2.2. Autenticación multifactor (MFA) en accesos a sistemas críticos:

- ☐ MFA en el 100 % de los accesos remotos y de administración
- ☐ MFA en > 75 % de accesos críticos
- ☐ MFA en algunos sistemas, sin cobertura sistemática
- ☐ No se utiliza MFA de forma relevante
- ☐ No sabe / No responde

2.2.3. Segmentación y microsegmentación de la red:

- ☐ Se aplican políticas de segmentación y microsegmentación basadas en roles, activos y sensibilidad
- ☐ Solo existe segmentación básica (VLANs, zonas) para separar entornos
- ☐ Segmentación mínima o inexistente
- ☐ No sabe / No responde

2.2.4. Verificación continua y basada en contexto (usuario, dispositivo, ubicación, comportamiento):

- ☐ Se combinan señales de contexto (dispositivo, geolocalización, comportamiento anómalo) para ajustar el acceso
- ☐ Se tienen controles contextuales limitados (por ejemplo, por IP o país)
- ☐ No existe verificación contextual más allá de usuario/contraseña
- ☐ No sabe / No responde

2.3. Criptografía y preparación post-cuántica

2.3.1. Estado del uso de criptografía en datos en tránsito:

- ☐ Todos los servicios críticos usan protocolos seguros actualizados (TLS configurado según buenas prácticas)
- ☐ La mayoría, con algunas excepciones heredadas
- ☐ Hay un uso mixto de protocolos seguros e inseguros
- ☐ No existe una política clara sobre cifrado en tránsito
- ☐ No sabe / No responde

2.3.2. Estado del cifrado de datos en reposo para sistemas ENS:

- ☐ Se cifran sistemáticamente datos sensibles y sistemas de categoría MEDIA/ALTA
- ☐ Se cifran parcialmente (solo bases de datos críticas o dispositivos móviles)
- ☐ El cifrado es excepcional y no sistemático
- ☐ No se utiliza cifrado en reposo
- ☐ No sabe / No responde

2.3.3. ¿Se ha realizado algún análisis sobre exposición a amenazas criptográficas avanzadas (incluida la computación cuántica)?

- ☐ Sí, con informe específico sobre impacto y plan de transición
- ☐ Sí, pero de forma exploratoria, sin plan concreto
- ☐ No, pero es un tema identificado en el radar estratégico
- ☐ No, y no se considera relevante
- ☐ No sabe / No responde

2.3.4. ¿Existe un inventario de activos y servicios que dependen de algoritmos criptográficos vulnerables o susceptibles a serlo?

- ☐ Sí, inventario completado y actualizado
- ☐ Iniciado, pero incompleto
- ☐ No se ha iniciado
- ☐ No sabe / No responde

3. Operación, incidentes y ciberresiliencia

3.1. Gestión de incidentes

3.1.1. ¿Dispone la organización de un procedimiento formal de gestión de incidentes de seguridad alineado con las guías CCN-STIC y el ENS?

- ☐ Sí, formal y operativo (se aplica habitualmente)
- ☐ Sí, pero se aplica de forma irregular
- ☐ En elaboración
- ☐ No existe procedimiento formal
- ☐ No sabe / No responde

3.1.2. Registro y clasificación de incidentes:

- ☐ Todos los incidentes se registran, clasifican por impacto y se reportan según ENS/NIS2
- ☐ Se registran incidentes relevantes, pero sin clasificación sistemática
- ☐ Solo se documentan incidentes graves o mediáticos
- ☐ No hay registro estructurado de incidentes
- ☐ No sabe / No responde

3.1.3. ¿Se calculan indicadores como MTTD (tiempo medio de detección) y MTTR (tiempo medio de respuesta)?

- ☐ Sí, para todos los sistemas críticos
- ☐ Sí, pero solo para algunos servicios (por ejemplo, SOC tercerizado)
- ☐ No, pero se prevé hacerlo
- ☐ No se calculan estos indicadores
- ☐ No sabe / No responde

3.1.4. ¿Con qué frecuencia se realiza un análisis de causas raíz (post-mortem) tras incidentes significativos?

- ☐ Siempre, con informes y acciones de mejora
- ☐ Ocasionalmente, según gravedad
- ☐ Rara vez o nunca
- ☐ No aplica / No sabe

3.2. Monitorización, detección y respuesta

3.2.1. Cobertura de monitorización (logs, eventos, correlación):

- ☐ La práctica totalidad de sistemas críticos están integrados en un SIEM / SOC
- ☐ Una parte relevante está monitorizada, pero hay huecos significativos
- ☐ Monitorización básica (logs locales, sin correlación centralizada)
- ☐ No existe monitorización estructurada
- ☐ No sabe / No responde

3.2.2. Modelo de operación de SOC / capacidad de respuesta:

- ☐ SOC interno 24x7
- ☐ SOC híbrido (interno + proveedor externo)
- ☐ SOC totalmente externalizado
- ☐ No se dispone de SOC ni de capacidad organizada de respuesta
- ☐ No sabe / No responde

3.2.3. ¿Se realizan ejercicios periódicos de simulación de incidentes (tabletop, drills técnicos, simulacros de crisis)?

- ☐ Sí, al menos una vez al año, incluyendo a la alta dirección
- ☐ Sí, pero restringidos al equipo técnico
- ☐ Esporádicamente, sin planificación estructurada
- ☐ No se realizan
- ☐ No sabe / No responde

3.3. Continuidad de negocio y ciberresiliencia

3.3.1. ¿Existen planes de continuidad de negocio (BCP) y de recuperación ante desastres (DRP) que incluyan explícitamente ciberincidentes?

- ☐ Sí, integrados y probados regularmente
- ☐ Sí, pero solo documentados, sin pruebas periódicas
- ☐ Parciales (para algunos servicios críticos)
- ☐ No existen BCP/DRP formales
- ☐ No sabe / No responde

3.3.2. Objetivos de tiempo de recuperación (RTO) y punto de recuperación (RPO):

- ☐ Definidos, aprobados y conocidos por las áreas implicadas
- ☐ Definidos informalmente, pero no documentados
- ☐ No definidos
- ☐ No sabe / No responde

3.3.3. ¿Se miden y reportan indicadores de cumplimiento de RTO/RPO tras ejercicios o incidentes reales?

- ☐ Sí, y se integran en los informes de ciberresiliencia
- ☐ Sí, pero sin seguimiento estructurado
- ☐ No se miden
- ☐ No sabe / No responde

3.3.4. Integración de la ciberseguridad en la gestión global de crisis:

- ☐ La ciberseguridad forma parte del comité de crisis y de los planes generales
- ☐ Solo se incorpora en crisis cuando el incidente es claramente tecnológico
- ☐ No existe integración formal
- ☐ No sabe / No responde

4. Recursos, cultura y formación

4.1. Presupuesto y recursos humanos

4.1.1. Proporción estimada del presupuesto TI dedicado a ciberseguridad:

- ☐ < 3 %
- ☐ 3–5 %
- ☐ 6–10 %
- ☐ > 10 %
- ☐ No se dispone de ese dato

4.1.2. Dotación de personal específico de ciberseguridad (equivalentes a jornada completa):

- ☐ 0 (se gestiona “a ratos” desde TI)
- ☐ 1–2
- ☐ 3–5
- ☐ 6–10
- ☐ > 10
- ☐ No sabe / No responde

4.1.3. ¿Existe un rol de CISO o Responsable de Seguridad de la Información formalmente designado?

- ☐ Sí, con dedicación plena y posición adecuada en el organigrama
- ☐ Sí, pero con dedicación parcial o encuadre organizativo débil
- ☐ Funciones repartidas sin figura única
- ☐ No existe este rol
- ☐ No sabe / No responde

4.2. Formación, concienciación y cultura

4.2.1. Programas de formación en ciberseguridad para el personal:

- ☐ Plan anual de formación estructurada, con registro de asistencia
- ☐ Acciones puntuales (charlas, cursos esporádicos)
- ☐ Formación limitada a perfiles técnicos
- ☐ No se realizan actividades de formación específicas
- ☐ No sabe / No responde

4.2.2. Campañas de concienciación (phishing simulado, boletines, etc.):

- ☐ Campañas periódicas con indicadores de resultados (tasa de clic, reporte, etc.)
- ☐ Algunas campañas puntuales sin métricas asociadas
- ☐ No se realizan
- ☐ No sabe / No responde

4.2.3. Percepción de la cultura de seguridad en la organización:

- ☐ Integrada: la seguridad se percibe como parte del valor del servicio
- ☐ Aceptada: se cumple “porque toca”
- ☐ Tolerada: se percibe como carga burocrática
- ☐ Resistida: se busca activamente eludir controles
- ☐ No sabe / No responde

5. Métricas, indicadores y uso de la información

5.1. Definición y gestión de indicadores

5.1.1. ¿Dispone la organización de un cuadro de mando de ciberseguridad basado en indicadores definidos (alineados o no con ENS/CCN-STIC-815)?

- ☐ Sí, formal, mantenido y utilizado en la toma de decisiones
- ☐ Sí, pero con actualización irregular
- ☐ Cuadros de mando parciales, sin visión integral
- ☐ No existe cuadro de mando estructurado
- ☐ No sabe / No responde

5.1.2. Tipos de métricas predominantes:

- ☐ De cumplimiento (porcentaje de medidas implantadas, auditorías superadas, etc.)
- ☐ De eficacia (reducción de incidentes, tiempos de respuesta)
- ☐ De eficiencia (coste por incidente, coste por control)
- ☐ De madurez (niveles, scoring)
- ☐ No se han definido tipos de métricas explícitamente

5.1.3. ¿Se usan las guías CCN-STIC-815 y 824 como referencia para diseñar indicadores?

- ☐ Sí, son la base principal
- ☐ Sí, junto con otros marcos (NIST, ISO, etc.)
- ☐ Conocidas pero poco utilizadas
- ☐ No se conocen / No se utilizan
- ☐ No sabe / No responde

5.2. Integración con planificación y ROI

5.2.1. ¿Se utiliza la información de INES/AMPARO para priorizar inversiones y planes de mejora?

- ☐ Sí, forma parte explícita de la planificación anual de seguridad
- ☐ Se considera como uno de varios inputs
- ☐ Se rellena por obligación, pero apenas se usa para planificar
- ☐ No se utiliza más allá de cumplir el trámite
- ☐ No sabe / No responde

5.2.2. ¿Se han definido indicadores o modelos internos para estimar el retorno de la inversión (ROI) en ciberseguridad?

- ☐ Sí, con fórmulas que relacionan reducción de riesgo, impacto y coste
- ☐ Sí, pero con aproximaciones cualitativas o semi-cuantitativas
- ☐ No, pero se reconoce la necesidad
- ☐ No, y no se considera una prioridad
- ☐ No sabe / No responde

5.2.3. ¿Se elaboran informes ejecutivos de ciberseguridad para la alta dirección utilizando datos de indicadores ENS/INES/AMPARO?

- ☐ Sí, con periodicidad establecida (mensual, trimestral, etc.)
- ☐ Sí, pero solo en contextos específicos (auditorías, crisis, presupuestos)
- ☐ Muy ocasionalmente
- ☐ No se elaboran informes ejecutivos estructurados
- ☐ No sabe / No responde

6. Visión futura y prioridades estratégicas

6.1. En su opinión, ¿cuáles son las tres prioridades estratégicas de ciberseguridad de su organización para los próximos 2–3 años?

(Respuesta abierta)

6.2. ¿Qué barreras principales encuentra para avanzar en la adecuación ENS y la mejora de indicadores (recursos, cultura, complejidad regulatoria, etc.)?

(Respuesta abierta)

6.3. Si tuviera que elegir una sola idea que le gustaría que quedara clara a la alta dirección al ver el informe resultante de esta encuesta, ¿cuál sería?

(Respuesta abierta, se permite ironía responsable)